El phishing que pasó todos los filtros

SPF ▪ DKIM ▪ DMARC ▪ — y aun así era falso

Análisis técnico de una campaña activa suplantando Amazon España

Lisa Moreno

SOC Analyst

Me Llegó este email el 1 de abril de 2026

Logo real, colores de Amazon, número de caso, firma con nombre y dirección. Parecía completamente legítimo.

Screenshot real del email recibido

amazon

Atención al Cliente

NUEVA RESPUESTA · Caso de Soporte #1775033599 · 01.04.2026

Compensación - Caso #1775033599

Estimado/a Lisa M,

Me acabo de dar cuenta de que tu caso de soporte de hace exactamente un año (**01.04.2025**) no fue respondido por un error en nuestro sistema. Enseguida le escribí a mi jefe Richard y le expliqué que hiciste una queja en la tienda, pero que los detalles también se perdieron.

Puedo ver en nuestros registros que hubo un problema con un artículo que compraste, y que no pudiste devolverlo ni cambiarlo. Eso no está bien y va en contra de nuestra política. Lo sentimos mucho.

Hemos decidido **darte una compensación**. Como este problema tardó mucho tiempo en resolverse, la compensación es bastante buena. No te preocupes por nada, Lisa — eres un cliente muy importante para nosotros y queremos hacer las cosas bien.

⏱ Solo un paso más — tarda menos de 1 minuto

Para confirmar que eres tú y verificar tu correo [redacted], por favor completa nuestra pequeña encuesta de 1 minuto. Así podemos procesar tu compensación y asegurarnos de que te llegue a ti.

Reclamar indemnización

Si el botón no funciona, copia y pega este enlace en tu navegador:
https:\\www.amazon.es\devoluciones-y-sustituciones\1775033599

Un cordial saludo,
Marina Racionero
Administradora Regional de Respuestas
Oficina Central

Falcon Way, Shire Road
Welwyn Garden Town, Hertfordshire, AM5 2PW

©2026 Amazon.com, Inc. o sus afiliados. Todos los derechos reservados.

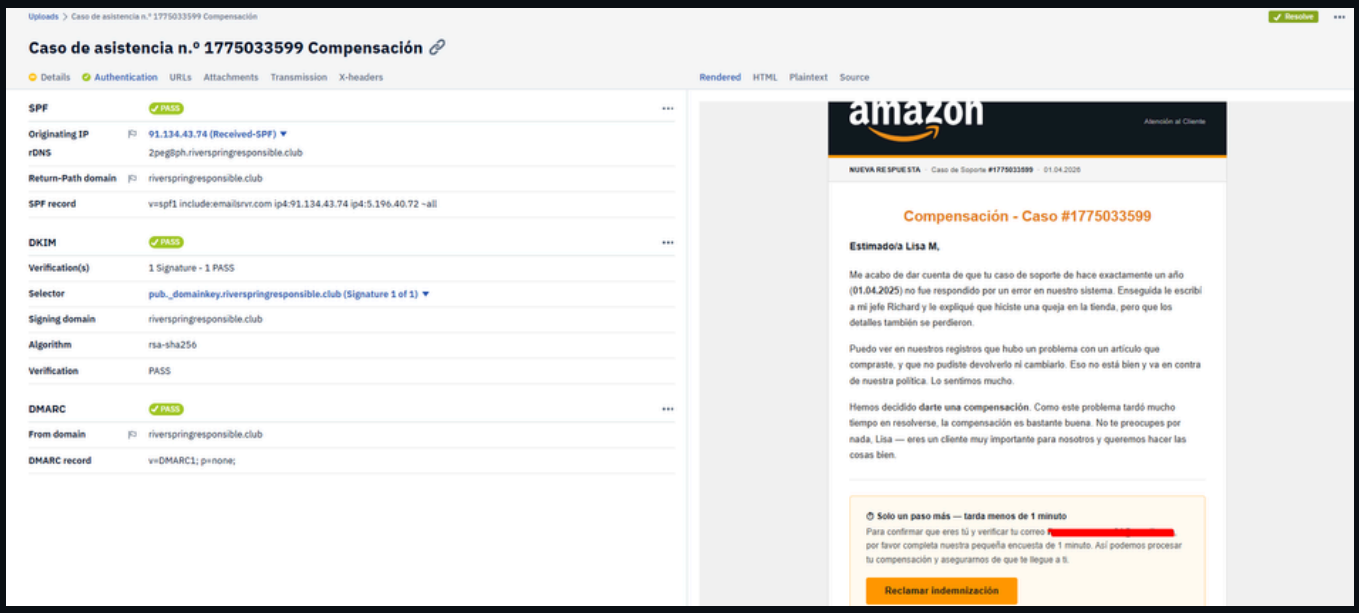
A simple vista parecía legítimo — pero hay señales ocultas

Pasó los TRES controles de autenticación

SPF, DKIM y DMARC son los estándares que verifican si un email es legítimo.

Este correo fue analizado de forma manual con la herramienta phistool.

PhishTool — Authentication tab



¿Por qué pasan los tres si es phishing?

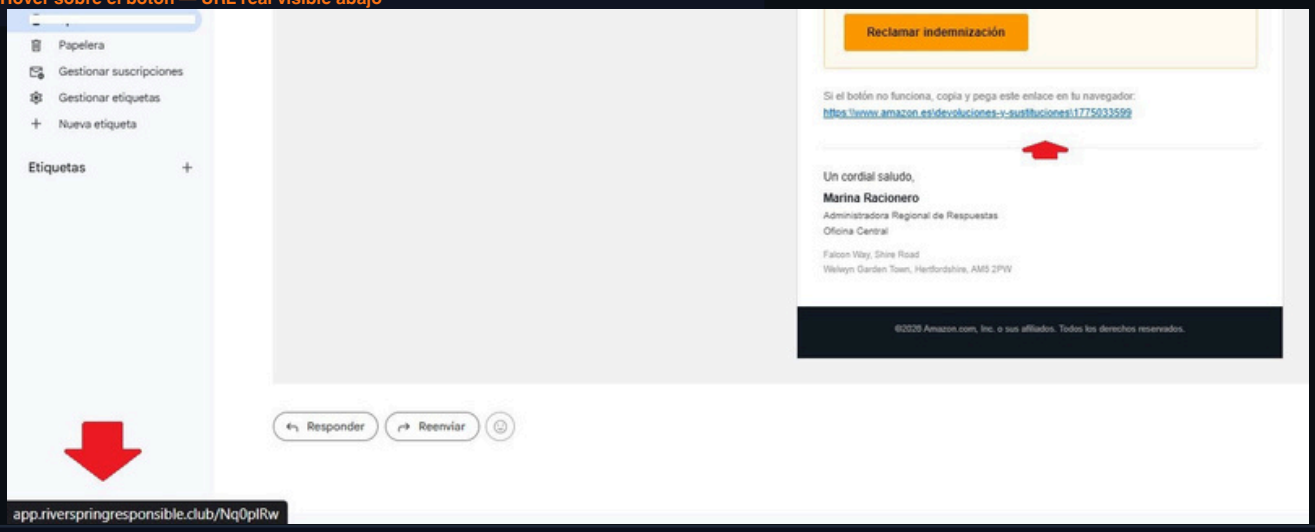
El atacante registró su propio dominio y configuró SPF/DKIM/DMARC correctamente. Autenticado. Falso.

Autenticado no significa legítimo.

El botón decía amazon.es — la URL real era otra

Al pasar el cursor sobre el botón, la barra inferior del navegador revela la verdad.

Hover sobre el botón — URL real visible abajo



Texto visible:

https://www.amazon.es/ devoluciones-y-sustituciones/...

URL real del botón:

app.riverspringresponsible .club/Nq0plRw ← ID por víctima

Más técnicas en este email:

Zero-width characters en asunto (invisibles, rompen filtros antispam)

·Homoglyph: la 'o' de 'Amaz■n' es Unicode

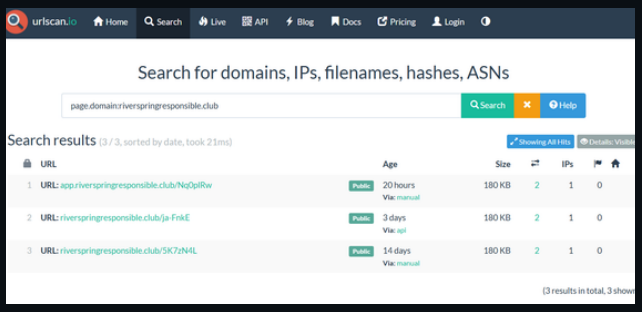
Evasión de Regex:

Muchos filtros de seguridad (motores de búsqueda de patrones) están configurados para detectar únicamente https://. Al usar https:\\, el atacante logra que el enlace pase desapercibido por escáneres automáticos simples.

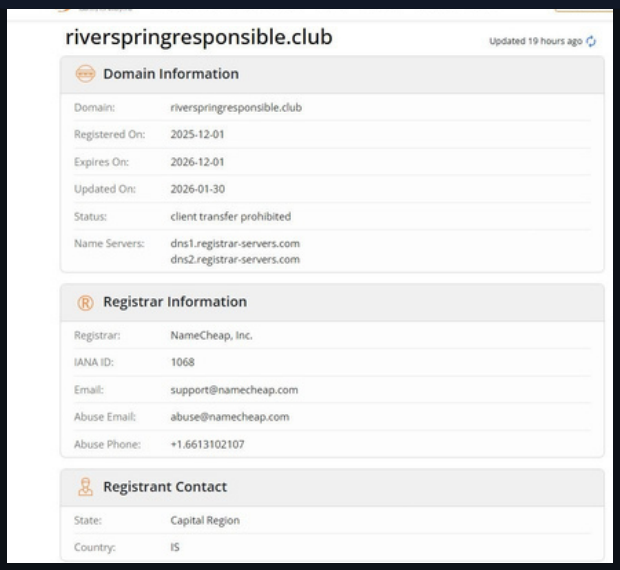
Un dominio preparado. Una campaña activa.

riverspringresponsible.club—registrado4mesesantes.Campañaactiva13+días en 3 países.

URLScan.io — 3 víctimas detectadas



WHOIS — NameCheap + privacidad Islandia



Dic 2025
Registrado 4 meses antes del ataque

NameCheap
Registrador barato privacidad total

3 países
EEUU · Bélgica · España

13+ días
Infraestructura efímera desaparece tras atacar

MITRE ATT&CK Mapping

T1566.002	**Phishing**	Spearphishing con enlace malicioso
T1027	**Obfuscated Files**	Zero-width characters en el asunto
T1036	**Masquerading**	Suplantación visual de Amazon
T1583.001	**Acquire Infrastructure**	Dominio registrado para el ataque
T1665	**Hide Infrastructure**	WHOIS privado + infraestructura efímera

Indicadores de Compromiso (IOCs)

Dominio	`riverspringresponsible.club`
IP	`91.134.43.74`
Remitente	`f.vsj@riverspringresponsible.club`
URL 1	`app.riverspringresponsible.club/Nq0plRw`
URL 2	`riverspringresponsible.club/ja-FnkE`
URL 3	`riverspringresponsible.club/5K7zN4L`

Lo que este análisis nos enseña

SPF/DKIM/DMARC no son suficientes

Un atacante puede configurarlos en su propio dominio. Autenticado no significa legítimo.

Verifica siempre el dominio, no el nombre visible

El nombre 'Devoluciones AMZ' es decorativo. El dominio real lo dice todo.

Pasa el cursor antes de hacer clic

El texto decía amazon.es. La URL real era riverspringresponsible.club.

Compensaciones inesperadas = señal de alerta

Si no lo solicitaste, desconfía. La urgencia y la vaguedad son tácticas de ingeniería social.

Análisis técnico completo: lisamorenoit.github.io

Herramientas: PhishTool · URLScan.io · WHOIS · Google Admin Toolbox

¿Has recibido algún phishing que parecía legítimo? **Cuéntamelo**